Azure Key Vault Managed HSM

Microsoft 365 Customer Managed Key implementation guide

Author: Alex Etin (Senior Consultant), Naresh Gupta (Senior Consultant)

This guide outlines a backup, restore, and disaster recovery strategy for **Azure Key Vault Managed HSM** in **GCC High, GCC and Commercial** environments, offering both conceptual guidance and a practical runbook to safeguard Microsoft 365 Customer Key assets and ensure compliance.

Introduction

Contoso operates in highly regulated sectors — including government services and healthcare — handling sensitive data such as **Protected Health Information (PHI)** and **Controlled Unclassified Information (CUI)** in collaboration with partners across the Department of Defense and Veterans Affairs. To satisfy stringent security and compliance requirements (including **FedRAMP High**, **DoD Impact Level 4 (IL4)** for CUI, **NIST SP 800-171/CMMC**, and **HIPAA** for health data), Contoso operates its Microsoft 365 services in Microsoft's **GCC High** cloud environment. This U.S. government-accredited cloud platform uses **FIPS 140-3 Level 3 validated hardware** and provides a physically isolated, US-only environment accredited at the FedRAMP High impact level, ensuring that Contoso's sensitive data and keys are handled in accordance with federal security standards.

Within this context, **Microsoft 365 Customer Key** plays a vital role: it allows Contoso to **control the encryption keys** used to protect data at rest across Microsoft 365 services. Customer Key adds an extra layer of encryption on top of Microsoft's baseline volume-level encryption (BitLocker and Distributed Key Manager) by letting organizations bring their own keys to protect cloud data at the application level. By implementing Customer Key, Contoso ensures that its Exchange email data, SharePoint/OneDrive files, Teams chats and recordings, and other Microsoft 365 content are encrypted with keys stored in **Contoso's own Azure Key Vault Managed HSMs**. This approach gives Contoso **exclusive authority** over those keys and the exclusive ability to grant or revoke access to its data, aligning with compliance frameworks that mandate robust encryption and **customer-controlled key management** practices. Organizations explicitly authorize Microsoft 365 to use these keys for value-added services such as eDiscovery, anti-malware, anti-spam, and search indexing, while retaining the ability to revoke or replace those keys as needed.

Important: Customer Key gives control over root encryption keys that can affect the entire organization. Mistakes with these keys can lead to **service interruptions or permanent data loss**. Additionally, Customer Key encrypts **only data at rest in the cloud** — it does not protect on-premises mailboxes or files.

This guide provides comprehensive step-by-step instructions for deploying Microsoft 365 Customer Key for Contoso's tenants. The implementation focuses on a **Multi-Workload Data Encryption Policy (DEP)** to cover multiple services (Teams, Exchange Online, etc.) and a **SharePoint/OneDrive DEP** for files, along with an **appendix on mailbox-level DEPs** for individual Exchange Online mailbox encryption when needed. By following this guide, Contoso's IT administrators can configure and manage Customer Key to achieve greater data protection and meet compliance requirements, while understanding the key design decisions (e.g. using a tenant-wide policy versus per-mailbox policies) and the responsibilities that come with managing encryption keys.

Data Sovereignty & Compliance

Contoso maintains sole control over encryption keys, satisfying government and healthcare regulations (FedRAMP High, HIPAA, NIST SP 800-171/CMMC) that require customer-managed encryption and key sovereignty.

Comprehensive Data Protection

A Multi-Workload encryption policy covers emails, Teams messages, Copilot data, Windows 365 Cloud PCs, and more; a separate SharePoint/OneDrive policy secures files — ensuring all Microsoft 365 content at rest is encrypted with Contoso's keys.

Transparent User Experience

Encryption and decryption occur behind the scenes without disrupting users. Microsoft 365 services continue to function normally while Contoso's keys enforce data protection, preserving productivity and compliance posture.

Purpose

This document provides Contoso with a comprehensive guide to implement **Customer Managed Keys (CMK)** for Microsoft 365 services in both **IL2 (Commercial)** and **IL4 (GCC High)** environments. The services addressed include **Exchange Online, Teams, SharePoint Online, and OneDrive for Business**, with step-by-step **implementation instructions** for all relevant workloads (Exchange Online, SharePoint Online, OneDrive, and Teams via Multi-Workload encryption). Key topics covered include:

- A **comparison of the process in GCC High vs. Commercial** environments and a **detailed technical and compliance overview**
- The required **Azure Key Vault / Managed HSM setup** and the **onboarding process** for GCC High tenants (which involves coordination with Microsoft due to the isolated nature of GCC High)
- The creation and assignment of **Data Encryption Policies (DEPs)** for each workload
- Guidance on **key lifecycle tasks** (such as rotation and revocation/purge)
- How Customer Key fulfills compliance mandates — including FedRAMP High and DoD IL4 requirements for encryption and key management — and what responsibilities Contoso must uphold (e.g. managing key security and availability)

Visual aids (tables and diagrams) are included to illustrate key processes and decision points, and references to official Microsoft documentation and the Service Trust Portal are provided for further validation.

Microsoft 365 Data Encryption Policies (DEP) Overview

Data Encryption Policies (DEPs) are the mechanism in Microsoft 365 for applying Customer Key encryption to different data **scopes** (sets of workloads or mailboxes). In Customer Key deployment, one or more DEPs are created and assigned to specify which encryption keys protect which data. There are **three types of DEPs** in Microsoft 365, each serving a different scope:

Data Encryption Policy Type	Coverage & Purpose	Key Details & Constraints
Multi-Workload DEP (Tenant-Wide)	Multiple Microsoft 365 services (tenant-scope). Encrypts data across several core workloads for all users: Microsoft Teams (chat messages, channel messages, voice & video meeting recordings, notifications), Exchange Online (service-level mailbox data, user metadata, e-mail headers, and any mailboxes not encrypted by a mailbox-specific DEP), Microsoft 365 Copilot (cached/copied AI interaction data), Microsoft Purview Information Protection (Exact Data Match schemas, sensitivity label configurations), and Windows 365 Cloud PC service (Enterprise cloud PC disk images, including Frontline Dedicated and Shared modes). *Note: SharePoint Online/OneDrive content and Teams files are not covered by this policy and require a separate DEP*.	Only 1 Multi-Workload DEP can be active per tenant. Once activated, all new data in covered services is encrypted with the Customer Keys; existing Exchange data is re-encrypted on next access, while existing Teams data remains under Microsoft's keys (only new Teams content post-assignment is encrypted with the Customer Key). Rolling back to Microsoft-managed keys is a controlled process requiring a Microsoft support request, and data purge via key revocation is not supported for multi-workload DEPs (to prevent tenant-wide data loss).
SharePoint/OneDrive DEP	SharePoint Online and OneDrive for Business content. Encrypts all documents and files stored in SharePoint sites and OneDrive accounts for all users (this implicitly covers files shared via Microsoft Teams, as Teams files reside in SharePoint).	Single-geo tenants can have one SharePoint DEP per tenant; multi-geo tenants can have one per geography. Once assigned, all content in SharePoint/OneDrive is automatically re-encrypted using Customer Keys. Rolling back to Microsoft-managed keys is not supported once Customer Key is enabled — this commitment should be planned carefully. If TriWest (or any organization) later decides to discontinue, Microsoft currently requires a support case to discuss possible options; there is no self-service "off" switch.
Exchange Mailbox-Level DEP (Optional)	Specific Exchange Online mailboxes. Allows targeting individual user mailboxes, shared mailboxes, Office 365 group mailboxes, resource mailboxes, or public folders with customer-managed encryption. Only mailboxes explicitly assigned to a mailbox DEP are encrypted with the Customer Key; other mailboxes remain under default service encryption or the tenant-wide policy.	Provides granular control when only specific mailboxes require Customer Key or different keys. Up to 50 mailbox-level DEPs can be active per tenant, and each mailbox can have at most one such policy. Each protected mailbox must be licensed for Microsoft 365 E5 or have the appropriate advanced compliance add-on. When applied, a mailbox's contents are re-encrypted under the Customer Key (new emails immediately; existing data upon next access or movement). If the policy is removed, the mailbox reverts to Microsoft-managed keys or the active tenant-wide policy. Unlike multi-workload policies, mailbox-level keys can be revoked to cryptographically delete specific mailbox data (per-mailbox data purge).

Table 1: Overview of Microsoft 365 Data Encryption Policies and Their Scope. Each DEP links two customer-managed keys (for high availability) and controls which data is encrypted. Tenant-wide policies provide broad, automatic coverage but cannot be easily rolled back, while mailbox-level policies offer selective control with the unique advantage of enabling targeted crypto-deletion.

Why Multi-Workload vs. Mailbox-Level?

For broad protection of **all** data in the tenant, a **Multi-Workload DEP** is typically simpler and ensures no gaps in coverage. **Mailbox-level DEPs** remain available for special cases — for example, if only a subset of mailboxes needs Customer Key encryption, or if different keys are required for different groups of users. Critically, the two approaches can **coexist**: a mailbox with its own assigned DEP will use that mailbox-specific key, while all other mailboxes (and the broader Exchange Online data such as service metadata) fall under the tenant-wide Multi-Workload policy.

Contoso's decision, confirmed by its stakeholders, is to use the **Multi-Workload policy as the primary method** for Exchange Online encryption, rather than creating numerous individual mailbox policies. This reduces administrative overhead while still encrypting all mailboxes by default. The mailbox-level approach and its procedures are documented in the Appendix for reference and potential future use.

Tradeoff consideration: While Multi-Workload provides simplicity and breadth, it lacks per-mailbox data purge capability. If Contoso anticipates needing to **cryptographically destroy** the data of specific mailboxes (e.g. during decommissioning or breach response), those mailboxes should be assigned dedicated mailbox-level DEPs to preserve the crypto-deletion option.

Prerequisites and Key Setup

Before implementing Customer Key, Contoso must ensure the following foundational requirements are in place:

- **Licensing:** Verify that the tenant has the appropriate licenses that include rights to Customer Key features. Typically, this means **Microsoft 365 E5 (or Office 365 E5)** plans, *or* the **Microsoft Purview Advanced Compliance** add-on licenses for the needed users. Each Exchange Online mailbox that will be encrypted by a Customer Key DEP must be in a supported plan (E5 or equivalent).
- **Azure Subscriptions:** Two separate **Azure subscriptions** under Contoso's Azure AD (Microsoft Entra) tenants are required to host the encryption key vaults/HSMs. Using **two distinct subscriptions** provides isolation and resilience for the two independent key stores. As a best practice, Microsoft recommends having **different members of the organization manage one key in each subscription**, and these subscriptions should be used **only to administer encryption keys** for Microsoft 365. *Note:* Free, Trial, Sponsorship, MSDN, and Legacy Support subscriptions are **not eligible** for Customer Key — use paid production subscriptions.
- **Azure Key Vault Managed HSMs:** In each of the two subscriptions, create a **Key Vault (Premium SKU)** or an **Azure Managed HSM** instance dedicated to storing the

Customer Key material. Microsoft strongly recommends the **Premium SKU** (which uses HSMs to protect keys) over the Standard SKU (which uses software-protected keys). Both **Soft Delete and Purge Protection must be enabled** on each key vault (with a **minimum 90-day retention** for deleted items) at the time of creation — these settings are mandatory for Customer Key and **cannot be changed after the vault is created**. If firewall is enabled on the key vault, the **"Allow Trusted Microsoft Services"** option must be selected.

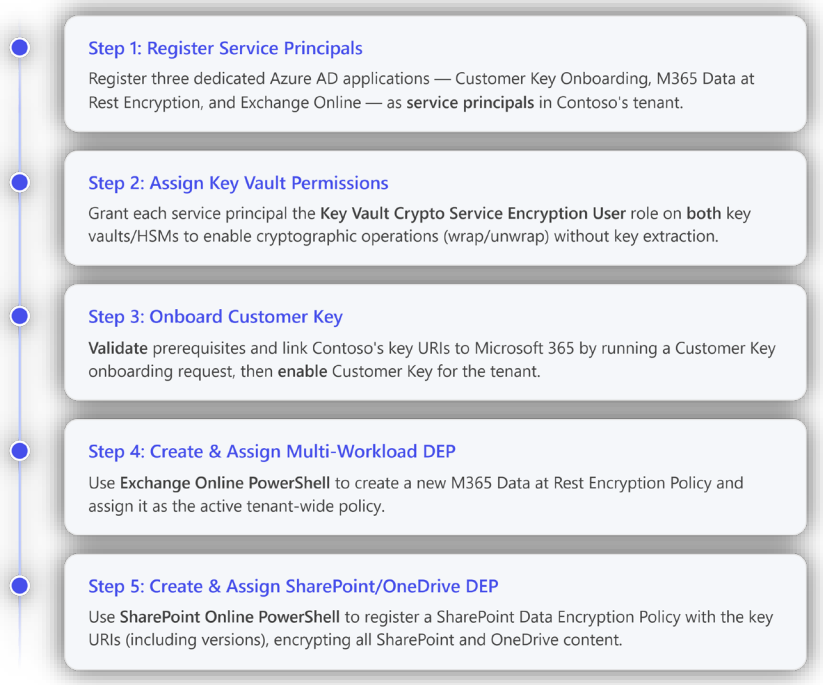
- **Customer Keys (Root Keys):** Generate a **pair of cryptographic keys** — one key in each vault/HSM — to serve as the **primary and secondary Customer Keys**. Keys must be **RSA 2048-bit or higher** and **must have no expiration date** (do not set an "Expires" attribute). An expired or deleted key would render data inaccessible, so key longevity and durable storage are critical. Microsoft recommends using **dedicated key pairs per major workload**; for full coverage, this means **3 key pairs (6 keys total)** — one pair for the Multi-Workload DEP, one for the SharePoint DEP, and one for any Exchange mailbox-level DEP (if used). Each key pair should reside in the two separate HSM/Key Vault instances prepared above.
- **Administrative Access:** Ensure you have **Global Administrator** privileges in the Microsoft 365 tenant (to configure encryption policies), as well as **Exchange Online Administrator** rights (to run mailbox and tenant encryption PowerShell cmdlets). You will also need **Owner/Contributor access** in the Azure subscriptions to create keys and set access policies on Key Vaults/HSMs. Microsoft recommends using roles with the **fewest permissions** necessary to improve security.
- **PowerShell Environment:** Set up a **Windows PowerShell 7** (or later) environment with the necessary modules: the **Az PowerShell module** (v4.4.0 or higher recommended) for Azure AD and Key Vault management, and the **Exchange Online PowerShell V2 module** for EXO cmdlets. Install the **SharePoint Online Management Shell** if managing SharePoint via a separate module. Using the latest versions of these modules is recommended for compatibility.
- **Microsoft Support (GCC High Only):** In **GCC High/DoD** tenants, the Customer Key feature may require back-end enablement by Microsoft. **Prior to enabling Customer Key**, Contoso should open a **support ticket** with Microsoft to request Customer Key activation for the tenant. In commercial tenants, this step is unnecessary — the onboarding cmdlet in subsequent steps will enable the feature automatically. In GCC High, by contrast, Microsoft will perform internal setup once requested.

Implementation Steps for Multi-Workload Data Encryption Policy (Tenant-Wide)

This section assumes familiarity with Azure Key Vault operations. The official Microsoft documentation for Customer Key is available at the following resources:

- Overview of Customer Key
- Set up Customer Key
- Manage Customer Key
- Roll or rotate a Customer Key or an availability key

With prerequisites in place, the process involves registering special Azure AD identities for the service, granting them access to the keys, onboarding the tenant to use Customer Key, and finally creating and assigning the encryption policies. The high-level steps are illustrated below:



Step 1: Register the Customer Key Service Principals in Azure AD

Microsoft 365 uses **dedicated Azure AD service principal accounts** to access Contoso's keys during encryption and decryption operations. Three important application IDs need to exist as service principals in the tenant directory:

- **Customer Key Onboarding Service** — Application ID: **<Application ID>** (facilitates the initial setup of Customer Key in the tenant)
- **M365 Data at Rest Encryption Service** (for Multi-Workload DEP) — Application ID: **<Application ID>**
- **Exchange Online** (for mailbox encryption) — Application ID: **<Application ID>**

Using the Azure PowerShell **Az** module (after running Connect-AzAccount to log in to the Azure AD tenant), execute the following commands for **each** of the above application IDs:

```
# Check if the service principal exists
Get-AzADServicePrincipal -ServicePrincipalName <APPLICATION_ID>

# If not present, create the service principal
New-AzADServicePrincipal -ApplicationId <APPLICATION_ID>
```

Replace <APPLICATION_ID> with each of the GUIDs listed (one at a time). For each ID, first try Get-AzADServicePrincipal; if it returns no result, run the New-AzADServicePrincipal command to register it. After this step, the three service principals — **"Customer Key Onboarding"**, **"M365 Data at Rest Encryption"**, and **"Office 365 Exchange Online"** — should be visible in the tenant's Azure AD. *(For SharePoint Online, a separate service principal "Office 365 SharePoint Online" is typically pre-existing in the tenant, so no manual registration is required for that service)*.

GCC High Note: Even after registering these principals, enabling Customer Key still requires Microsoft's back-end activation in GCC High. Ensure that the support ticket (from Prerequisites) is in progress so that once your configuration is validated, Microsoft can enable Customer Key for the tenant.

Step 2: Assign Key Vault Permissions to the Service Principals

Next, grant each of the above service principals access to **use the keys** in both Azure Key Vaults/HSMs. Assign the built-in role of **Key Vault Crypto Service Encryption User** on each key vault to the corresponding service identities. This role assignment can be done through Azure Portal or Azure PowerShell. In summary:

1. Open the **Access Control (IAM)** settings for **each Key Vault/HSM**.
2. Add a **Role Assignment** of **Key Vault Crypto Service Encryption User** for the following service principals (find by name or Application ID):
    - *M365 Data at Rest Encryption* (for multi-workload encryption)
    - *Office 365 Exchange Online* (for mailbox encryption)
    - *Office 365 SharePoint Online* (for SharePoint/OneDrive encryption)

Each of these three service principals must be granted the role on **both** key vaults/HSMs (so that whichever vault key is needed, the service can access it). The Key Vault Crypto Service Encryption User role includes permissions such as **UnwrapKey/WrapKey** and is narrowly scoped to cryptographic operations — it means the Microsoft 365 services can use Contoso's keys for encryption but **cannot extract them**. **After assigning the roles, wait ~5–10 minutes** for the permissions to propagate before proceeding; failing to wait may cause subsequent steps to error due to Azure eventually consistent permissions.

Step 3: Onboard the Tenant for Customer Key

Now the tenant must be **onboard** for Customer Key, which links the prepared key information with Microsoft 365 services. In a **commercial** Microsoft 365 tenant, this is achieved via a PowerShell module called **M365CustomerKeyOnboarding**, which is used to run an **onboarding request** for each encryption scenario (workload). In **GCC High**, this process is coordinated with Microsoft Support (per previous notes), but performing the **validation** steps locally is still recommended:

Install the module (commercial tenants): If on a commercial tenant, install the Customer Key module by running:

```
Install-Module M365CustomerKeyOnboarding
Import-Module M365CustomerKeyOnboarding
```

In GCC High, the module may not be available to tenants — instead, Microsoft will run the equivalent process internally on your behalf once you provide the necessary information.

Prepare the key information: Identify the two Key URIs for the primary and secondary keys in each scenario. A **Key URI** is the URL of the Key Vault key including its name (e.g. https://<VaultName>.vault.azure.net/keys/<KeyName>). Gather: the Tenant's GUID (Directory ID), the two **Azure Subscription IDs** where the key vaults reside, and the **Key URIs** for the primary and secondary keys for each scenario (Multi-Workload, SharePoint, and optionally Exchange Online).

Run onboarding in "Validate" mode: Use PowerShell to construct a New-CustomerKeyOnboardingRequest for each scenario. For instance, for the multi-workload policy:

```
$request = New-CustomerKeyOnboardingRequest -Organization "<TenantID>" `
    -Scenario MDEP -Subscription1 "<SubscriptionID1>" -KeyIdentifier1 "<PrimaryKeyURI>" `
    -Subscription2 "<SubscriptionID2>" -KeyIdentifier2 "<SecondaryKeyURI>" `
    -OnboardingMode Validate
```

This command sends a request to Microsoft 365 to validate that all prerequisites are in place for the specified scenario (in this example, **MDEP** — the Multi-Workload DEP). The service will check for common issues and return any **FailedValidations** in the $request object. Ensure that $request.FailedValidations is empty (indicating all checks passed) before proceeding. The following table lists the validation rules checked during onboarding:

Rule Name	Description	Solution
OrganizationHasRequiredServicePlan	Verifies whether your organization has the required licenses	See Prerequisites
KeyNeverExpires	Ensures that the key has no expiration date	Verify key expiration settings in Configuration-specific setup
KeyOperationsSupported	Verifies whether the key supports required operations for the workload	Verify permissions in Configuration-specific setup

RecoveryLevel	Checks if the key recovery level is Recoverable	Ensure both soft delete and purge protection are enabled
SubscriptionInRequestOrganization	Confirms that Azure subscription belongs to your organization	Make sure the subscription was created within the specified tenant
SubscriptionsCountPerScenario	Confirms that two subscriptions were provided	Ensure onboarding request includes two subscriptions
SubscriptionUniquePerScenario	Ensures two unique subscriptions per scenario	Double-check that both subscription IDs are different
VaultExistsinSubscription	Confirms that the AKV/Managed HSM is part of the given subscription	Verify vault configuration

Table 2: Onboarding Validation Rules. These rules are checked automatically when running the onboarding request in validation mode. All checks must pass before proceeding to enablement.

Complete the onboarding (Enable): Once validation is clean, run the command again with -OnboardingMode Enable (or provide the necessary info to Microsoft support for GCC High). This finalizes the setup and **onboards the tenant for Customer Key**, linking the key URIs provided with the Microsoft 365 services for encryption. Microsoft 365 will generate internal encryption keys (often called **Availability Keys** or DEP keys) wrapped with the provided Customer Keys at this point, but **data encryption does not begin until the DEP is assigned** in the next step.

Step 4: Create and Assign the Multi-Workload Encryption Policy

With the tenant now onboarded for Customer Key, Contoso can create the **Multi-Workload Data at Rest Encryption Policy** and assign it to the tenant. Both creation and assignment are done via **Exchange Online PowerShell** (the EXO V2 module), as this module includes the cmdlets for organization-level encryption policies:

Connect to Exchange Online PowerShell: If not already connected from previous steps, run:

```
Connect-ExchangeOnline -Organization "<TenantDomainName>"
```

Use Global Admin or an account with sufficient permissions.

Create the Multi-Workload DEP: Use the New-M365DataAtRestEncryptionPolicy cmdlet to create the policy object, specifying the two key URIs (**without versions**, so the policy always uses the latest version of the key in each vault):

```
New-M365DataAtRestEncryptionPolicy -Name "Contoso-MultiWorkload-Policy" `
    -AzureKeyIDs "<PrimaryKeyURI>","<SecondaryKeyURI>" -Description "Tenant-wide encryption
policy"
```

Choose a descriptive name for the policy. **(Do not include key *versions*; the service will use the current version of each key and seamlessly use new versions as you roll them)**.

Activate (assign) the Multi-Workload DEP: Execute the assignment cmdlet to make this new policy active for the tenant:

```
Set-M365DataAtRestEncryptionPolicyAssignment -DataEncryptionPolicy "Contoso-MultiWorkload-Policy"
```

Only one multi-workload policy can be active at a time; assigning a policy replaces any previously active one. Once this command is run, **encryption will begin automatically** for the relevant workloads in the background. Specifically:

- Any **new data** in Teams, Exchange (for mailboxes without an individual DEP), Microsoft 365 Copilot, etc., will now be encrypted with Contoso's keys.
- Existing **Exchange Online** data that was previously encrypted with Microsoft's keys will be **re-encrypted under the new keys upon next access**.
- For **Teams**, only newly generated content (chats, messages, recordings) after enabling Customer Key will use the new keys — **historical Teams content remains encrypted with Microsoft's standard keys**, as Customer Key for Teams is **not retroactive**. This is a key reason to deploy the Multi-Workload DEP early, so that as much data as possible will be protected going forward.

Verification: To confirm that the Multi-Workload DEP is active, run:

```
Get-M365DataAtRestEncryptionPolicyAssignment
```

The output should show the name (or GUID) of the active tenant-wide policy. You can also inspect the policy's details with Get-M365DataAtRestEncryptionPolicy -Identity <PolicyName> to see the key URIs and ensure they match the intended keys. In the **Microsoft 365 compliance center** or **Exchange Admin Center**, there may also be indications that Customer Key is enabled for the organization. No user-facing changes should be apparent except **improved compliance posture** — data access and functionality remain the same, as encryption and decryption happen transparently.

Step 5: Create and Assign the SharePoint/OneDrive Encryption Policy

SharePoint Online and OneDrive data are *not* covered by the multi-workload policy and require their own DEP. This DEP encrypts content stored in SharePoint and OneDrive, including Teams files stored in SharePoint. Multi-geo tenants can create one DEP per geo; single-geo tenants can create one DEP. The process for SharePoint is separate and utilizes the **SharePoint Online PowerShell module**:

Obtain Key URIs with Version: Retrieve the **version of** Key URIs for the two keys dedicated to the SharePoint/OneDrive encryption policy. Unlike the multi-workload and Exchange policies, the **SharePoint cmdlet requires specifying the exact Key Version GUID** for each key. You can get the Key URI along with its version by running Get-AzKeyVaultKey -VaultName <VaultName> in Azure PowerShell and copying the **ID** property (which includes the full URL with the key name and version).

Connect to SharePoint Online: Use the SharePoint Online Management Shell or PowerShell module. Connect to the SharePoint Admin URL for Contoso's tenant. For example:

```
Connect-SPOService -Url "https://contoso-admin.sharepoint.com"
```

Use appropriate admin credentials. *(In GCC High, the admin URL will use .sharepoint.us instead of .sharepoint.com)*.

Register the SharePoint DEP: Use the Register-SPODataEncryptionPolicy cmdlet to create the new policy:

```
Register-SPODataEncryptionPolicy -PrimaryKeyVaultUrl "<PrimaryKeyURI_withVersion>" `
    -SecondaryKeyVaultUrl "<SecondaryKeyURI_withVersion>"
```

Replace the URLs with the **complete URI including the key version** for each key (as obtained above). After running this command, SharePoint Online will begin **encrypting all content at rest in SharePoint and OneDrive** using the Customer Keys. This includes files in document libraries, SharePoint site data, OneDrive files, and Teams files stored in SharePoint. The encryption process for existing content may take time depending on the volume of data but happens in the background without user impact; any **newly uploaded or modified files are encrypted immediately** using the new keys.

Verification: Run Get-SPODataEncryptionPolicy to view the current policy settings and status for SharePoint. The output will show the key URIs and their versions, and a **Status** (e.g. "Enabled" if encryption is active). In the SharePoint admin center, you should see that Customer Key is enabled, and you can monitor encryption progress. All user actions (accessing files, uploading new files, etc.) should continue normally — the encryption is transparent to users and applications.

Important: As with Exchange, once SharePoint Customer Key encryption is enabled, **you cannot revert SharePoint/OneDrive back to Microsoft-managed keys**. If, in the future, Contoso decides to discontinue Customer Key for SharePoint, Microsoft currently requires opening a support case to discuss possible options (there is no self-service "off" switch). However, you *can* rotate the Customer Keys (by updating them to new key versions) or disable the policy for future data as needed.

Post-Implementation Considerations and Key Management

With the **Multi-Workload** and **SharePoint** encryption policies in place, Contoso's data across Exchange, Teams, SharePoint, OneDrive, and related workloads is now protected with customer-managed keys. End users should **not** notice any change in day-to-day usage of

Microsoft 365 services — encryption and decryption occur behind the scenes. However, there are important **ongoing management and compliance considerations**:

- **Verification and Monitoring:** Administrators should verify that all policies are in effect. For Exchange, use Get-DataEncryptionPolicy and Get-M365DataAtRestEncryptionPolicyAssignment to list policies and confirm the Multi-Workload DEP is active. For SharePoint, verify Get-SPODataEncryptionPolicy shows the expected primary and secondary keys and that the status is Enabled. It is recommended to periodically review the **Microsoft 365 compliance center** and **Azure Monitor/Azure AD logs** for any warnings (e.g. expirations or access issues related to Customer Key). Microsoft 365 audit logs can also capture key-related events, such as encryption policy changes or unusual key usage, which should be monitored as part of Contoso's security operations.
- **Key Rotation:** Over time, Contoso may wish to **rotate** (roll over) the encryption keys for compliance or security best practices. The process for rotating Customer Keys typically involves creating new key versions in the Azure Key Vaults, then updating the DEP to use the new key URIs. For example, to rotate keys for the Multi-Workload DEP, use Set-M365DataAtRestEncryptionPolicy -Identity "<PolicyName>" -PrimaryKey "<NewKeyURI1>" -SecondaryKey "<NewKeyURI2>". The service will rewrap the internal encryption (DEP) key with the new Customer Keys **without re-encrypting all data**, ensuring a seamless rotation process.
- **Temporary Suspension:** In certain scenarios (e.g. during testing or an incident), it might be necessary to **temporarily disable** a DEP. For Multi-Workload, you can disable the policy using Set-M365DataAtRestEncryptionPolicy -Identity "<PolicyName>" -Enabled $false to stop encrypting new data with the Customer Key. Existing data remains encrypted, but new data will use Microsoft's keys until the policy is re-enabled.
- **Revoking Keys & Data Deletion (Crypto-Shredding):** One advantage of Customer Key is the ability to **cryptographically delete** data by revoking your keys. **Revoke access** to both the primary and secondary keys (for example, by using Azure Key Vault to disable or delete the key material) to immediately prevent Microsoft 365 from accessing the data, making the protected data unreadable. However, **purging data by key revocation is supported *only* for mailbox-level DEPs, not for multi-workload policies**. A multi-workload DEP spans many services and users; purging it would make broad swaths of data inaccessible. To purge specific content (e.g. a particular mailbox's data), use a mailbox-level DEP and then revoke those keys. If Contoso ever needs to initiate a data purge, work with Microsoft to ensure the proper procedures are followed.
- **Compliance Documentation:** Ensure that Contoso updates its internal documentation and risk assessments to reflect the use of Customer Key. Microsoft provides **audit reports** (e.g. **SSAE 18 SOC 2** reports) that describe how Customer Key controls are implemented. Contoso's regulators or auditors may request evidence that encryption keys are customer-controlled — this can be demonstrated through Microsoft's compliance reports and Contoso's own records of key ownership.

Implementing Customer Key fortifies compliance stance by demonstrating adherence to key management requirements (for instance, under HIPAA, having sole control of encryption keys adds an extra layer of protection for ePHI).

Appendix: Exchange Online Mailbox-Level Encryption (Data Encryption Policies)

This appendix provides a detailed breakdown of how to configure and manage **Exchange Online mailbox-level DEPs**. Contoso has chosen a tenant-wide Multi-Workload policy as the primary encryption method for simplicity and broad coverage. However, mailbox-level encryption remains available if needed for specific cases (e.g. VIP mailboxes or separate key management domains).

Creating a Mailbox-Level DEP and Assigning it to Mailboxes

Choose or create Customer Keys for the mailbox DEP: You may use a separate pair of keys (in two vaults) dedicated to a particular set of mailboxes or reuse an existing pair. Ensure you have the Key Vault URIs (without versions) for the two keys. Each key **must** be in an Azure Key Vault/Managed HSM with soft delete and purge protection enabled and have no expiration.

Connect to Exchange Online PowerShell: Use the Exchange Online PowerShell (EXO V2) module:

```
Connect-ExchangeOnline -Organization "<TenantDomainName>"
```

Create a new Data Encryption Policy: Run the New-DataEncryptionPolicy cmdlet to create the policy object in Exchange Online:

```
New-DataEncryptionPolicy -Name "<MailboxPolicyName>" -Description "Encryption for specific
mailboxes" `
    -AzureKeyIDs "<PrimaryKeyURI>","<SecondaryKeyURI>"
```

Choose a descriptive name for the policy (perhaps tied to a department or data category). This creates a DEP that references the two Customer Key URIs (no key versions needed — Exchange will always use the latest version of each key). The policy is now available to be assigned to mailboxes.

Assign the DEP to mailbox(es): For each mailbox that should be encrypted with this Customer Key, execute:

```
Set-Mailbox -Identity "<UserMailbox or Alias>" -DataEncryptionPolicy "<MailboxPolicyName>"
```

You can apply the policy to multiple mailboxes (by running the cmdlet for each target mailbox, or scripting it for bulk assignments). Each mailbox will shortly **begin re-encrypting its mailbox data** under the new Customer Key policy. This process (called *re-wrapping*) is handled automatically by Exchange: for an already-encrypted mailbox, the master key

wrapping its content is replaced. Users might notice a brief delay if their mailbox is being moved as part of encryption, but otherwise the change is seamless.

Verification: Use the Exchange Online cmdlets to verify encryption status. For example:

```
Get-DataEncryptionPolicy | Format-List Name, AzureKeyIDs, Status
Get-Mailbox -Identity "<Mailbox>" | Select DataEncryptionPolicy
Get-MailboxStatistics -Identity "<Mailbox>" | Select EncryptionEnabled, DataEncryptionPolicyId
```

These commands will show the list of DEP policies (with their associated key URIs and status), confirm which policy (if any) is assigned to a given mailbox, and display encryption-related stats for a mailbox. A newly assigned mailbox might show an encryption status or policy ID only after the re-encryption is underway or completed.

Managing Mailbox-Level Encryption Policies

- **Adding/Removing Mailboxes:** You can assign additional mailboxes to an existing policy at any time using Set-Mailbox -DataEncryptionPolicy. If a mailbox no longer requires Customer Key encryption, remove the policy by setting it to **null**:

```
Set-Mailbox -Identity "<Mailbox>" -DataEncryptionPolicy $null
```

This unassigns the Customer Key DEP from that mailbox, causing it to revert to using Microsoft-managed keys for encryption (or the Multi-Workload key, if one is active for the tenant). The underlying data will be re-encrypted accordingly after removal.

- **Rotating Keys:** As with other policies, update the keys in a mailbox-level DEP by using the Set-DataEncryptionPolicy cmdlet to point to new Key URIs (after creating new key versions in Azure Key Vault). The process is similar to rotating keys for the Multi-Workload DEP — the mailbox content's encryption will be re-wrapped with the new keys seamlessly in the service. It is important to monitor that all mailboxes successfully re-encrypt with the new keys after a rotation.
- **Limits:** Keep in mind the limits for mailbox-level policies: a maximum of **50** mailbox DEPs can be active in a tenant, and each mailbox can only be associated with **one** DEP at a time. If more than 50 distinct encryption groupings are required, consider whether using the tenant-wide Multi-Workload policy (possibly in combination with mailbox DEPs for a few special cases) could cover the requirements. In practice, 50 mailbox policies have been sufficient for most organizations by grouping mailboxes with similar security needs under the same DEP.
- **Key Revocation (Data Purge):** In scenarios where Contoso needs to permanently destroy data (for example, decommissioning a project or responding to a security breach), having that data encrypted with Customer Key provides a path for **crypto-deletion**. By design, **only mailbox-level DEPs support targeted data purge via key revocation**. If Contoso revokes (deletes or disables) the two Azure Key Vault keys

used in a mailbox DEP and notifies Microsoft (through a support process) to initiate the data purge, Exchange will **cryptographically purge** the contents of those mailboxes by rendering the data irretrievable (also referred to as the **"data purge path"** in Microsoft documentation). This capability is **not available for multi-workload or SharePoint DEPs**, since those cover broad swaths of data. Thus, if per-mailbox data destruction is a requirement, planning to use dedicated mailbox-level policies for those datasets is advisable.

Conclusion

Implementing Microsoft Purview Customer Key in Contoso's Microsoft 365 tenant provides increased control over data security, ensuring that sensitive healthcare and defense-related information remain encrypted with keys under Contoso's sole control. This guide has covered the end-to-end process — from initial planning and key setup through activation for Exchange, SharePoint/OneDrive, and Teams — and highlights how this solution satisfies critical compliance requirements such as **FedRAMP High** and **DoD IL4**.

It is recommended to perform this implementation in a **non-production environment first**, if available, to validate all steps, and then proceed to production with Microsoft's support on standby. After deployment, maintain an ongoing schedule for key management tasks, such as reviewing access logs, updating key versions if needed (key rotation), and ensuring that documentation (both internal and with regulators or partners) reflects the use of Customer Key.

By implementing Customer Key, Contoso takes a proactive stance in safeguarding its data. This not only fulfills compliance mandates but also provides assurance that even in a cloud environment, the organization retains ultimate control over the privacy and security of its most sensitive information. The combination of **GCC High's built-in protections** and **Contoso's own key management** creates a strong defense-in-depth for the data entrusted to Microsoft 365.

Additional References and Supporting Content:

Microsoft Purview Customer Key Documentation:

- **Overview of Customer Key** — Explains the concept and scope of encrypted workloads
- **Setup Guide for Customer Key** — Step-by-step official instructions on enabling Customer Key
- **Managing Customer Key** — How to create and manage DEPs (useful for ongoing operations)
- **Rolling Keys** — Procedures to roll/rotate a Customer Key or the availability key
- **Availability Key** — In-depth explanation of the availability key's role and security

Service Trust Portal (Compliance Documents):

- **FedRAMP Marketplace & Microsoft Compliance Offerings:** Lists Microsoft 365 GCC High's FedRAMP and DoD SRG IL4 authorizations

- **Microsoft 365 SOC 2 Audit Report:** Details controls like Customer Key for encryption and data purging
- **SSAE 18 SOC 2 Type II** report — Can be used to demonstrate to auditors that Microsoft's processes (including Customer Key handling) are independently audited

Community and Support:

- **Microsoft Tech Community – Public Sector**: Blogs and forums where GCC High users discuss features like Customer Key and share best practices
- **Microsoft Support & Premier Services:** For GCC High, leverage Microsoft's support for any troubleshooting. Contoso should consider a support agreement that ensures quick response due to the critical nature of controlling its own keys

This is a preliminary document and may be changed substantially prior to final commercial release of the software described herein.

The information contained in this document represents the current view of Microsoft Corporation on the issues discussed as of the date of publication. Because Microsoft must respond to changing market conditions, it should not be interpreted to be a commitment on the part of Microsoft, and Microsoft cannot guarantee the accuracy of any information presented after the date of publication.

This guide is for informational purposes only. Microsoft makes no warranties, express or implied, in this document.

Complying with all applicable copyright laws is the responsibility of the user. Without limiting the rights under copyright, no part of this document may be reproduced, stored in, or introduced into a retrieval system, or transmitted in any form or by any means (electronic, mechanical, photocopying, recording, or otherwise), or for any purpose, without the express written permission of Microsoft Corporation.

Microsoft may have patents, patent applications, trademarks, copyrights, or other intellectual property rights covering subject matter in this document. Except as expressly provided in any written license agreement from Microsoft, the furnishing of this document does not give you any license to these patents, trademarks, copyrights, or other intellectual property.

© 2020 Microsoft Corporation. All rights reserved.

The example companies, organizations, products, domain names, e-mail addresses, logos, people, places, and events depicted herein are fictitious. No association with any real company, organization, product, domain name, e-mail address, logo, person, place, or event is intended or should be inferred.

Microsoft, list Microsoft trademarks used in your white paper alphabetically are either registered trademarks or trademarks of Microsoft Corporation in the United States and/or other countries.

The names of actual companies and products mentioned herein may be the trademarks of their respective owners.